The SolarWinds Supply Chain Attack (2020)

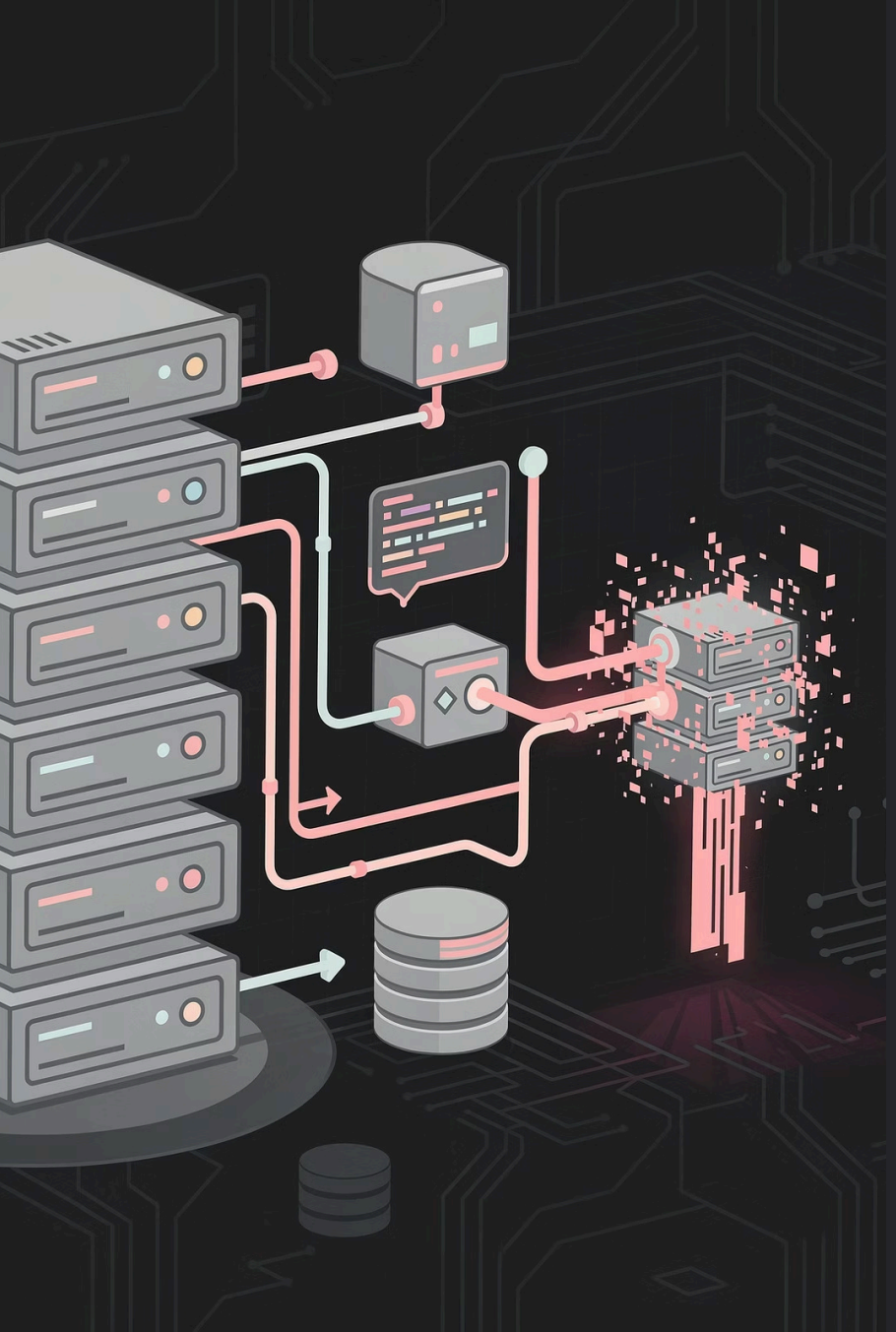
A Comprehensive Analysis Using Core Computer Security Concepts and Frameworks

COMP 3019 – Winter 2026 | Group 06

Avoy Das
202148474

Naimul Alam
202062659

Swacha Mallik
202313886



1. Introduction

The SolarWinds supply chain attack is widely considered one of the most significant cybersecurity incidents in recent history. Discovered in December 2020, it involved the compromise of SolarWinds' Orion software update process — a widely used IT management platform deployed by thousands of public and private organizations.

Attackers inserted malicious code into legitimate, digitally signed software updates. This was not a direct attack against one organization. It exploited the security assumptions built into software trust, using legitimacy itself as a weapon. This report analyzes the attack using CIA triad, threat classification, vulnerabilities, FIPS 200, design principles, attack surface analysis, attack trees, and security strategy.

2. Overview of the SolarWinds Attack

Stage 1: Vendor Compromise

Attackers gained access to SolarWinds' software build environment and inserted the SUNBURST malware into Orion updates. Because updates were properly signed, organizations installed them without suspicion.

Stage 2: Customer Exploitation

The malware created a backdoor enabling communication with command-and-control servers, lateral movement, and selective targeting of high-value systems. One company's weakness became many organizations' weakness simultaneously — a force multiplier through dependency relationships.

3. Basic Security Concepts: The CIA Triad

The SolarWinds attack shows that CIA triad objectives are deeply connected — a compromise of one becomes the starting point for others.

Integrity — Primary Failure

Attackers modified legitimate Orion updates by inserting malicious code. This corrupted the trustworthiness of the update process itself and was the foundation on which all later failures were built.

Confidentiality — Enabled by Integrity Breach

Once the malicious update created a foothold, attackers carried out espionage operations. The prior integrity breach reduced suspicion and allowed malware to remain active long enough to reach sensitive data.

Availability — Indirect Consequence

Though not the primary goal, availability was still at risk. Compromised systems required shutdown during investigation, and organizations had to suspend normal operations while rebuilding trust in core systems.

Key Conclusion: Integrity was compromised first → trusted access created → confidentiality breached → availability disrupted during recovery. One failure became the gateway to all others.

4. Threats, Attacks, and Vulnerabilities

Threat Classification

→ Deception

Malicious update presented as authentic software — central to the attack's success.

→ Usurpation

The Orion update mechanism was repurposed as a malware distribution channel.

→ Malicious Logic

SUNBURST backdoor embedded in legitimate software, enabling unauthorized disclosure and system control.

Vulnerabilities Exploited

- Weak protection of the software build environment
- Insufficient monitoring and detection
- Excessive system privileges
- Overreliance on trusted updates
- Weak internal network segmentation

5. Security Functional Requirements (FIPS 200)

The SolarWinds incident reflected breakdowns across multiple FIPS 200 control areas simultaneously — not just a single technical exploit.

1	**System & Information Integrity** Organizations failed to verify update integrity. This weakened all downstream defense layers.
2	**Configuration Management** Weak control over the build environment allowed unauthorized modification to spread risk to all dependent organizations.
3	**Audit & Accountability** Attack remained undetected for months. Visibility without meaningful analysis is insufficient.
4	**Incident Response** Delayed detection reflects inadequate preparation, not just slow reaction. Longer attacker presence meant deeper lateral movement.
5	**Risk Assessment** Supplier trust was treated as an assumption rather than a risk. The threat model was too narrow.
6	**Access Control** Broad privileges enabled privilege escalation and deeper compromise after initial entry.

6. Fundamental Security Design Principles

Least Privilege

Privileges were too broad. One foothold became many. Least privilege limits damage after prevention fails.

Complete Mediation

Trust granted too broadly after install. One successful deception became continuing authority.

Isolation

Poor segmentation allowed lateral movement. One compromised entry became an organizational problem.

Layering (Defense in Depth)

Organizations relied too heavily on update trust. When that failed, secondary controls were insufficient.

Psychological Acceptability

Routine update processes trained users to trust automatically — exploited by attackers.

Economy of Mechanism

SUNBURST was kept small and simple, helping it blend into normal behavior and avoid detection.

7. Attack Surface Analysis

The SolarWinds incident involved software, network, and human dimensions — it cannot be explained as a code problem alone.

Software Supply Chain

Primary surface. Compromising the build process transformed a legitimate function into a malware delivery channel, multiplying impact across all customers.

Internal Networks

Secondary surface. Weak segmentation and trusted internal relationships made lateral movement easier after initial installation.

Administrative Access

Privileged accounts converted presence into control. The more trusted a credential, the more damaging its misuse.

Monitoring & Human Oversight

Delayed detection shows that human judgment and organizational oversight can also be exploited through normal assumptions and delayed suspicion.

Conclusion: Reducing attack surface means shrinking trust-based exposure inside development, deployment, and administration — not only closing public-facing interfaces.

8. Attack Tree

Root Goal: Gain unauthorized access to sensitive systems and data

OR Path 1: Direct Attack

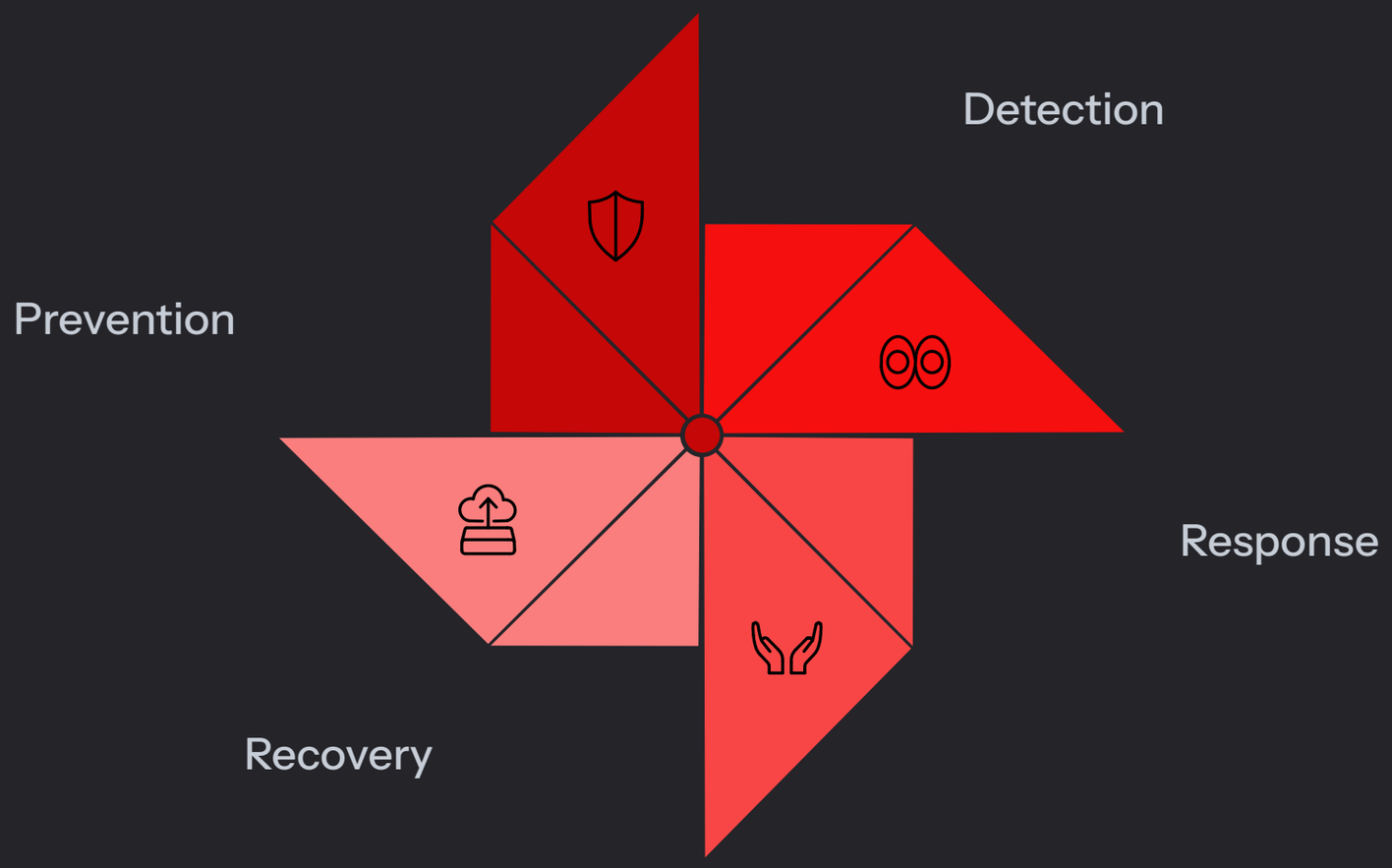
Attack target organizations directly. More difficult, less scalable, and more likely to trigger defensive attention. This path was not chosen.

OR Path 2: Supply Chain Compromise (Chosen)

1. Compromise the SolarWinds build environment
2. Insert malicious code into Orion updates
3. Pass through legitimate code-signing and trusted delivery
4. Victim organizations install the update
5. Establish persistence through the backdoor
6. Escalate privileges and move laterally
7. Reach high-value systems and sensitive data

Insight: Each step depended on the previous. Better build environment protection, integrity validation, monitoring, or segmentation at any node could have interrupted the chain.

9. Computer Security Strategy



Prevention

Must exist across the entire trust chain — not only at the customer level. Supplier development processes must also be secured.

Detection

A second major chance to limit harm after prevention fails. Must be a core capability, not an optional supplement.

Response

Breach cost grows over time. Delayed response gave attackers more time to explore and persist.

Recovery

A supply chain compromise damages trust itself. Recovery means rebuilding confidence in systems and processes, not only technical restoration.

10. Lessons Learned

1. **Never treat vendor trust as absolute**

   A trusted relationship can become an attack vector if not continuously verified.

2. **Integrity protection is foundational**

   Once trusted software is compromised, downstream organizations defend from within a poisoned trust channel.

3. **Defense in depth is essential**

   A compromise at one layer must not automatically become a full organizational compromise.

4. **Monitoring must recognize subtle behavior**

   Sophisticated attacks are defined by patience and low visibility — data collection alone is not enough.

5. **Supply chain risk must be included in risk assessment**

   Security includes the systems, vendors, and services on which your systems depend.

6. **Design principles are not theoretical extras**

   Least privilege, complete mediation, and isolation directly shaped how much damage attackers could do after entry.

11. Conclusion

The SolarWinds attack demonstrates how compromise of a trusted system can lead to widespread and long-lasting impact. Its success resulted from a chain of connected weaknesses: integrity was compromised at the update source, trust allowed malicious code into customer environments, weak monitoring delayed discovery, broad privileges enabled expansion, and insufficient segmentation allowed deeper reach.

Interconnected Failures

Failures spanned basic security concepts, threat categories, functional requirements, design principles, attack surfaces, and security strategy — all at once.

Trust as a Vector

Modern cybersecurity failures often spread through trust relationships and dependency chains rather than only through direct perimeter attacks.

Core Takeaway

Effective security depends on continuously verifying trust, limiting consequences of compromise, and preparing to detect and recover when prevention fails.

12. References

CISA. (2021). *SolarWinds and Active Directory/M365 compromise advisory.*

FireEye. (2020). *Highly evasive attacker leverages SolarWinds supply chain to compromise multiple global victims with SUNBURST backdoor.*

Memorial University. (2025a–f). *COMP 3019 Lecture Slides 01–06: Basic computer security concepts; Threats, attacks, and assets; Security functional requirements; Fundamental security design principles; Attack surfaces and attack trees; Computer security strategy.*

Microsoft Security Team. (2021). *Analyzing the SolarWinds supply chain attack.*

NIST. (2006). *FIPS 200: Minimum security requirements for federal information systems.*

Stallings, W. (2018). *Computer security: Principles and practice.*

Thank You!

Group 06 | COMP 3019 – Winter 2026

Avoy Das
202148474

Naimul Alam
202062659

Swacha Mallik
202313886

❓ Questions & Discussion

We welcome your questions on any aspect of the SolarWinds attack analysis — from the CIA triad and FIPS 200 controls, to attack surface analysis, design principles, or security strategy. Please feel free to ask!